改変検出・時刻証拠・障害復旧の実証評価 (v1)

Unjuno

2026年11月15日 / v1候補 / 未査読

要旨

本稿は、プレプリント公開物に対する意図的な改変、信頼設定の誤り、証拠の失効、公開処理の途中失敗を、OpenPreprint Kitがどの範囲で検出・拒否・復旧できるかを、実際に実行した試験に基づいて評価する。対象は固定したツールキット main（c51aa55edfeb41e43b2c86982765c5d0777771ed）である。実験は20の否定ケース（23判定）・復元試験・2件の実障害の記録・ローカル合成PKIによる失効/期限切れ/古いCRLの実測を含み、誤受理は0件だった。一方で、これらの試験は特定の実装・環境・信頼根の下での観測であり、未試験の入力や実装共通欠陥に対する一般化はできない。

キーワード: 改変検出、RFC 3161、信頼境界、PKI、復元、障害分析

1. 背景と目的

［論文A v2 / v1 の実運用報告［1］と重複する記述は、設計と初期CI評価までに限る。］本稿は、公開物を「意図的に壊す・すり替える・信頼根を誤る・失効させる」という攻撃者の視点で、既存の検証プログラム（verify_release, verify_evidence, preserve, timestamp, observation）がどこまで拒否できるかを測る。論文A（同キットの設計と実運用評価）は成果と限界を述べるものであり、本稿は検証機構自体の頑健性に絞る。

2. 関連研究

Gitのコミット日時は環境で指定できるため存在時刻の証明にならない［2］。RFC 3161はメッセージのダイジェストに対する認証局の時刻付与を規定し、署名・証明書連鎖・失効情報の検証を要求する［3］。GitHubのImmutable Releasesは公開後のタグと資産を固定するが、説明文等は編集可能である［4］。オンライン公開と保存の分離、すなわち「公開はGitHub、復元はオフライン」という方針は、本キット以外にも複製・バックアップ設計の一般論として広く知られている。これらを統合して検証可能なプレプリント流通を提供する具体実装として本稿は評価を行う。

3. 脅威モデル

資産	攻撃者が狙うもの	想定する失敗
公開PDF	改変・すり替え	別バイト列を正規版として通す
研究データ/コード	改変・追加	ハッシュ整合を装う
タイムスタンプ	署名偽造・nonce攪拌	時刻証拠を無効化する
信頼根	CA指紋/OID/CRLの誤り	攻撃者のTSA応答を受け入れる
復元物	ZIP引数/symlink	ディスク・展開を破壊/すり抜け
公開処理	途中失敗	ゴミのような公開状態を黙認

信頼境界は、**検証者が自ら選定した信頼ポリシー**（FreeTSA、CA指紋=2151b611…、policy OID 1.2.3.4.1）と、**外部に固定した期待ダイジェスト**である。同一運用者が公開者と検証者を兼ねるとき、独立性は保証されない（本評価はその限界を含む）。

4. 検証仮説と試験計画（H/T/D/C/U）

- **H**: 検証プログラムは、固定20ケースの改変/信頼誤設定/途中失敗を、それぞれ期待どおりに拒否する；オフライン復元は完全一致する。
- **T**: 次の対象を試験する。(1) PDF/データ/コード/manifest/SHA256SUMSの改変（a:素の改変、b:整合を外部レファレンスなしで整えた版）、(2) 欠落/余計なファイル、(3) 別repo/別版、(4) 誤CA指紋・誤Policy OID・nonce攪

拌・署名改変、(5) 失効/期限切れ/古いCRL（合成PKI）、(6) 危険ZIP、(7) 誤観測鍵/再署名、(8) INC-1/INC-2。

- **D**: 期待＝各ケース拒否・復元一致・誤受理0。1つでも誤受理があればFAIL。
- **C**: 同一コードによる共通欠陥（すべての試験が同じ実装で書かれている）、信頼根の一括差し替え、検証対象と証拠の同時差し替え。
- **U**: TSA時刻の精度（未記載）、cron時刻の系統制約、CRLの鮮度、検証と公開の同一オペレータ性。

計測の区別: 本稿の実験は (i) ローカル実暗号処理（Windows, OpenSSL 3.5.6, CPython 3.12.10）、(ii) ローカル合成PKI、(iii) 実TSA（FreeTSA）、の3種を区別して記録する。モック通信は使用していないが、合成公開物は実研究の成果ではない（デモ資産のみ）。

5. 結果

5.1 否定ケース（固定20件、23判定）

#	ケース	層	結果
1	PDF改変	バンドル整合	拒否（SHA不一致・SHA256SUMS/metadata不整合）
2	データ改変 (a/b)	バンドル整合/TSA結合	拒否/拒否
3	コード改変 (a/b)	バンドル整合/TSA結合	拒否/拒否
4	manifest改変 (a/b)	バンドル整合/TSA結合	拒否/拒否
5	資産欠落	バンドル整合	拒否
6	余計なファイル	バンドル整合	拒否
7	別リポジトリ	ソース特定	拒否
8	別版（v1→v2扱い）	ソース特定	拒否
9	誤CA指紋	信頼CAピン	拒否
10	誤policy OID	TSA OID	拒否
11	nonce不一致（他版のtsq流用）	RFC 3161 nonce結合	拒否

#	ケース	層	結果
12	署名バイト反転	TSA署名	拒否
13	失効TSA（ローカルPKIでrevoke 後）	失効確認	拒否
14	期限切れTSA（ローカルPKIで期限切れcert）	有効期限	拒否
15	古いCRL（nextUpdate 2019-11 → 2020-01 の CRL）	CRL鮮度	拒否（CRL has expired）
16	ZIPパストラバーサル	アーカイブ	拒否
17	重複member	アーカイブ	拒否
18	symlink member	アーカイブ	拒否
19	誤観測鍵（Ed25519）	観測署名	拒否
20	観測後の再署名改変	観測主張の再署名	拒否

spec は事前固定（negative-suite-spec.json, 2026-11-14）。誤受理は0件（23判定すべてを機械照合済み、negative-suite-results.json）。

5.2 オフライン復元

公開5版（実論文1＋合成デモ4）すべてで、匿名HTTPSダウンロードと一致するバイト列を保存ZIPから新規環境相当へ復元できた（paper v1: restore_byte_equality=true、デモ各版同様）。

5.3 途中失敗と保存

INC-1（WindowsのPATH欠陥による公開停止 SOURCE_COMMITTED）と INC-2（immutable読戻し競合）を観察した。INC-2は自動回復できず、手動の bounded retry追加が必要だった (PR #34/#35)。いずれの場合も、既存repo・既

存Releaseの削除/上書きは行わず、失敗記録（publication-report.json 等）はPASSに書き換えられなかった。**“PASSしないことを正しく記録する”という復旧能力そのものが、復号検証の一部である。**

5.4 正常系との対比

失敗が正しく検出・停止・記録される一方、正常系（5 Release＋再検証5回、復元5回、TSA 5回、復帰試験、合成デモのv1不変性確認）はすべてPASSした。ただし正常PASは「その設定・その環境での成功」に限る。

6. 失敗・反証・限界

- 未試験の入力に対する誤受理確率は0とは主張できない（事前固定20ケースに外挿できない）。
- 暗号方式（SHA-256/RFC 3161/Ed25519）の安全性そのものを証明しない。
- 同一コードベース・同一オペレータによる自己検証であり、独立再実装・交差実装の相互確認ではない。
- 古いCRLの拒否は「CRLが失効として報告される」ことの確認であり、CA compromise 後の歴史的LTVや強制再取得は保証しない。
- 本評価はWindowsと GitHub Actions Ubuntu の2環境だが、2環境も同一GitHubアカウント配下であり独立性は主張できない。
- INC-1の修正は cffconvert 検出部のみであり、同種の「子プロセスPATH」欠陥が他に存在する保証はない。

7. 再現性とデータ公開

- 対象 main: c51aa55edfeb41e43b2c86982765c5d0777771ed（CI: Validate/Quality/CodeQL/self-application すべて success）
- 否定試験: manuscripts/openpreprint-kit-robustness-eval/data/（spec・results・PKI記録・incident-analysis.json）
- 実験プログラム: manuscripts/openpreprint-kit-robustness-eval/analysis/（再実行手順は README.md）
- 環境: Windows + OpenSSL 3.5.6 + CPython 3.12.10（および Ubuntu 24.04 CI, run #43583374274）
- 各数値は原ログ/保存ZIP復元記録/GitHub APIレスポンスに基づく。推測で補った値はない。確認不能な項目は §9 で UNKNOWN と明記する。

8. 結論

事前固定された20ケースの改変・信頼誤設定・失効・危険なZIP・署名改変はすべて拒否され、保存ZIPからの復元は一貫して完全一致した。OpenPreprint Kitの検証経路は、少なくとも試験した範囲では「壊れた入力を拒否する」能力を持つ。反対に、失敗を正しく記録し公開を停止するという非暗号的な振る舞いも同様に検証済みであるのは、本評価の重要な帰結の1つである。実装欠陥の排除・独立検証者・独立監査は依然として未達であり、これらが揃うまでは本キットの公開物は「検証済み」であっても「完成」ではない。

9. UNKNOWN・未確証事項

項目	状態
TSA（FreeTSA）の時刻精度	UNKNOWN（証明書のaccuracy欄が記録されず、本稿では数値化できない）
CRLの更新頻度・維持責任	UNKNOWN（採用した時点は有効だが、継続と責任者は未確定）
検証相互独立性	UNKNOWN（同一オペレータ）
実GitHubのすべての障害モードでの生存性	UNKNOWN（INC-2で1例確認のみ）

著者・AI支援・公開状態

本稿はAI支援で作成された未査読のv1候補である。著者表示は「Unjuno」（所有者による申告、本人確認・独立証明ではない）、本文ライセンスはCC BY 4.0、コード・データは資産別ライセンスに従う。未査読・未監査であり、独立した人間による最終承認前に公開してはならない。

参考資料

[1] Unjuno. *OpenPreprint Kit — 実運用評価（v2）*.（本キット同梱、2026年11月）.

[2] Git Project. *git-commit(1) man page*. https://git-scm.com/docs/git-commit（2026-11-14確認）.

[3] Adams, C., Cain, P., Pinkas, D., Zuccherato, R. *RFC 3161 — Time-Stamp Protocol (TSP)*. IETF RFC 3161 (2001). DOI: 10.17487/RFC3161.

[4] GitHub. *Immutable releases*. https://docs.github.com/en/code-security/concepts/supply-chain-security/immutable-releases （2026-11-14確認）.

[5] OpenPreprint Kit. 本評価の一次証拠: manuscripts/openpreprint-kit-robustness-eval/data/（negative-suite-spec.json, negative-suite-results.json, incident-analysis.json）, Issue #5. https://github.com/Unjuno/openpreprint-kit/issues/5 .